

Curso de Especialización Ciberseguridad en las TIC

Práctica 1. Análisis y fortificación de la BIOS/UEFI.

Objetivos

- Configurar la BIOS para mejorar la seguridad del equipo y su contenido.
- Minimizar la exposición a ataques mediante la BIOS.
- Identificar amenazas y mecanismos de seguridad en la BIOS/UEFI.

Resumen

Autora: Marina del Pilar López Oliva

Octubre 2025

IES Camp de Morvedre

Obra publicada con [Licencia Creative Commons Reconocimiento Compartir igual 4.0](https://creativecommons.org/licenses/by-sa/4.0/)



Revisión

Revisión	Fecha	Descripción
1.0	24/10/2025	Realización de las tablas de BIOS
2.0	25/10/2025	Descripción de los apartados 1 y 2
2.1	26/10/2025	Realización de los apartados 3 y 4, y revisión del documento.

Índice de Contenidos

1. Introducción.....	4
2. Apartado 1. Identificación (gráfica y textual) de las características de seguridad en la BIOS/UEFI.....	4
3. Apartado 2. Fortificación (gráfica y textual) de las características de seguridad en la BIOS/UEFI.....	6
4. Apartado 3. Amenazas de seguridad en la BIOS/UEFI.....	7
5. Apartado 4. Mecanismos de seguridad en la BIOS/UEFI.....	8
6. Conclusión.....	12
7. Webgrafía.....	12

1. Introducción

Esta práctica consiste en configurar la BIOS de forma que esté debidamente protegido. Para ello, tenemos que encontrar el capítulo del manual del equipo de clase que hable de la BIOS e identificar todos los componentes que pueden ayudarnos para la seguridad de la BIOS.

Esta tarea se divide en cuatro apartados, el primero trata de identificar las características de seguridad albergadas en la BIOS. En este caso se añadiría una tabla de excel dónde pondrá todas las cualidades que he considerado de seguridad. A continuación, fortificaremos la BIOS y también ponemos la misma tabla con las mejoras que considero para tener una BIOS segura. Estas primeras partes las tendremos en la hoja de [auditoría de la BIOS](#).

Después, identificamos las diferentes amenazas que se pueden producir en la BIOS de clase a partir de un documento de CCN-CERT. Por último, con el mismo documento, describiremos gráfica y textualmente los mecanismos de seguridad que se pueden establecer en la BIOS.

2. Apartado 1. Identificación (gráfica y textual) de las características de seguridad en la BIOS/UEFI

En este apartado, vamos a mostrar cómo está actualmente configurada la BIOS. Para ello, hemos creado una tabla en Excel dónde ponemos todas las especificaciones de la BIOS del equipo de clase, llamada '[BIOS-inicial](#)'.

Al visualizar esta hoja, podemos ver los aspectos que tiene nuestra BIOS inicialmente. Ahora, podemos explicar qué impacto tienen estos aspectos en la seguridad cada aspecto, y qué hacer para mejorar la BIOS.

La versión de la BIOS nos ayuda a saber que no está actualizada, por lo que es recomendable actualizarla a la más reciente para incorporar parches de seguridad y correcciones de firmware.

En cuanto a la opción de "Signed Firmware Update" está bien activada, pues impide la instalación de firmware no autorizado. Sin embargo, las opciones activadas de "Legacy Options" o "Attempt Legacy Boot", sería mejor desactivarlas para que se funcione solo con UEFI y evitar cargas no verificadas. También encontramos un error en la configuración de "UEFI Boot Path Security" ya que

está activada excepto en el disco interno, podría reforzarse para que esté activada en todos los dispositivos.

En lo que se basa a las opciones de seguridad, encontramos varios fallos. Primero, no tiene habilitada ninguna contraseña, lo que permite modificar la BIOS sin control. Además, tampoco están habilitadas las contraseñas fuertes, estaría bien activar la política de contraseñas fuertes para mejorar la seguridad. El “Password Bypass” está bien desactivado, porque impide omitir las contraseñas durante el ataque. Sin embargo, el “Password Change” con la opción que tiene ahora, permite que usuarios no administradores cambien la contraseña, se debería restringir. Tanto el “UEFI Capsule” está bien configurado, ya que permite las actualizaciones firmware firmadas desde el sistema operativo. En cuanto a la opción de “TPM 2.0”, está bien activado pero el bypass físico, que tiene configurado, permite cambios sin intervención directa del usuario. Que no estén habilitadas “Admin Setup/Master Password Lockout” es un error, ya que no está activada ni el bloqueo del acceso a la configuración BIOS ni se bloquea tras intentos fallidos. Añadiendo que tenemos el “Chassis Intrusion” sin configurar, así que no detectará aperturas físicas del equipo. Por último, en esta sección, tenemos las opciones “Absolute” y “SMM Security Migration”. El primero está activado lo que permite rastrear y bloquear el equipo de forma remota. El “SMM” está también reforzando la protección del firmware.

Después pasamos al “Secure Boot”. En este apartado tenemos desactivada la opción de “Secure Boot Enable”, lo que puede provocar que arranquen sistemas operativos sin firmar. El modo de despliegue está configurado, con una clave sin personalizar de PK.

La opción del “Integrated NIC”, permite el arranque en red mediante PXE, lo que puede ser un riesgo potencial si no se controla el servidor. Si activamos el “Smart Reporting” nos puede ayudar en la monitorización de salud de discos. Todos los puertos de USB (rear/front) están configurados incluidos para arranque, para prevenir casos extremos habría que deshabilitarlos.

Pasamos ahora al “Intel Software Guard Extensions”, que está habilitado con 128MB enclave. Esto permite ejecutar aplicaciones en entornos aislados, lo que mejora la seguridad de ejecución.

En las opciones de “Power Management” tenemos desactivadas el “AC Recovery” y el “Auto On Time”, lo que no es relevante pero evita reinicios automáticos no

deseados. Que en el “Wake on LAN/WLAN” esté activado con PXE Boot, puede provocar una vulnerabilidad si no se usa.

El “USB Provision” y el “MEBx Hotkey” el AMT no está configurado pero el hotkey sí. Sería recomendable desactivarla si no se gestiona remotamente el equipo.

Si tenemos en cuenta la virtualización, es correcto tener habilitada la opciones de “Virtualization Technology”, ya que es necesario para máquinas virtuales seguras. Además, con la opción “VT for Direct I/O” habilitada mejoramos el aislamiento entre dispositivos virtuales seguras. Sin embargo, “Trusted Execution” está desactivado, activarlo reforzaría la integridad de ejecución y protección del entorno de arranque.

WLAN/WiFi y Bluetooth, son otras opciones de la BIOS, ambas activadas. No es una condición crítica, pero puede implicar riesgos si no se controlan las conexiones.

Por último, nos quedan las opciones de mantenimiento. “BIOS Downgrade” está activada, lo que permite volver a versiones anteriores que pueden exponer vulnerabilidades antiguas. La opción de “Data Wipe” está desactivada, pero puede ser útil habilitarla como mecanismo de borrado seguro por si se recicla. En cuanto a la recuperación, “BIOS Recovery from Hard Drive” está activada permitiendo la recuperación de firmware mediante el disco si se daña, pero el “Auto-Recovery” está desactivado.

3. Apartado 2. Fortificación (gráfica y textual) de las características de seguridad en la BIOS/UEFI

Una vez realizada la primera auditoría, hemos podido realizar la securización de la BIOS. Mi propuesta está en la hoja llamada ‘[BIOS-fortificada](#)’, dónde espero garantizar la máxima seguridad posible.

En primer lugar hemos decidido actualizar la BIOS para protegernos de ataques como BIOS malware. Después, hemos desactivado las opciones de “Legacy” para forzar el arranque en modo UEFI seguro. Y en el “UEFI Boot Path” hemos quitado la excepción para que verifique la integridad de todos los dispositivos de arranque sin excepción, asegurando que solo se carguen binarios firmados.

Basados en los aspectos de seguridad de la BIOS, hemos establecido las contraseñas para todo, configurado las contraseñas robustas, deshabilitar la

opción del “Password Change”, activar los “Lockout” y el “Chassis Intrusion”, deshabilitar la opción “PPI Bypass” del TPM, y activar el “Absolute”. Con todo esto hemos protegido el acceso a la BIOS y al arranque, garantizado la integridad del sistema, evitado ataques por fuerza bruta y conseguido alertas sobre manipulaciones.

Hemos activado y configurado el “Secure Boot” para asegurarnos de que solo se carguen sistemas operativos y controladores firmados digitalmente, evitando arranques de software no confiables.

En cuanto a las configuraciones del sistema, hemos deshabilitado el NIC, si no se utiliza el arranque remoto. Activamos el “Smart Reporting” y configuramos solo en los puertos necesarios el USB. Esto minimiza los vectores de ataque mediante red o dispositivos externos, y mejora la trazabilidad del hardware.

Desactivamos la opción de “Wake on LAN/WLAN” si no tenemos control seguro. Con todo lo del “Power Management” desactivado, evitamos reinicios o encendidos automáticos que podrían usarse para acceder al sistema fuera del horario controlado.

La opción de “MEBx Hotkey” he decidido deshabilitarla ya que así se reduce la superficie de ataque. Esto es teniendo en cuenta que no utilizamos gestión remota.

En cuanto a virtualización, solo es necesario activar el “Trusted Execution”, que nos asegura la integridad del arranque del sistema operativo.

Si no es necesario el “WLAN/WiGi” o el Bluetooth, es mejor desactivarlos, ya que eliminan vectores de ataque inalámbricos cuando las interfaces no se utilizan.

Por último, en el mantenimiento hemos desactivado la “BIOS Downgrade” para que no se instalen versiones antiguas vulnerables. Además, hemos activado el “Data Wipe” que nos asegura un borrado seguro en caso de reciclaje o baja del equipo. También he activado el “Auto-Recovery” para garantizar la recuperación ante corrupción del firmware.

4. Apartado 3. Amenazas de seguridad en la BIOS/UEFI

A continuación, vamos a identificar y explicar las amenazas que pueden ser relevantes para la clase, a partir del documento dado. Con este apartado se pretende comprender la importancia de las medidas aplicadas en la fortificación.

- Ataques iniciados por el usuario. Este ataque se produce cuando un usuario instala una actualización de BIOS no autenticada o manipulada. Puede ser por desconocimiento o de forma intencionada. En los equipos del aula, un alumno puede ejecutar un archivo descargado de internet o desde un USB sin firma. Con esto podría perderse el control del arranque, la persistencia de malware y el riesgo para el sistema.
- Ataques iniciados por software dañino. Consiste en que un malware con privilegios elevados modifica el firmware desde el sistema operativo, o aprovecha vulnerabilidades para instalar una BIOS maliciosa. Un alumno o profesor podría instalar un virus con privilegios de administrador, sin querer. Esto podría escribir en la BIOS y alterar el proceso de arranque. Lo que provoca un control del equipo antes de cargar el sistema operativo, evasión de antivirus y persistencia del ataque incluso tras formatear.
- Ataques basados en red. Un atacante consigue acceso y compromete directamente un servidor de actualización de sistemas BIOS. En nuestro caso, el centro podría descargar las actualizaciones desde un servidor no verificado o manipulado, por lo que todos los equipos podrían infectarse. Así sería capaz de controlar e infectar de manera indiscriminada todos aquellos sistemas que se nutran del servidor comprometido.

5. Apartado 4. Mecanismos de seguridad en la BIOS/UEFI

En cuanto a los mecanismos de seguridad aplicables en sistemas BIOS/UEFI, contamos con seis medidas. Esto nos ayudaría a mitigar los ataques comentados en la sección anterior.

- Instalación de contraseña de usuario y contraseña de administrador. Los sistemas BIOS/UEFI permiten establecer dos niveles de contraseñas, la de administrador y la del usuario. La del administrador protege el acceso a la configuración de la BIOS, solo quien conoce esta contraseña puede modificar las opciones del firmware. Y la del usuario restringe el acceso al equipo al finalizar la fase de arranque, antes de que se cargue el sistema operativo. En las imágenes siguientes, se muestran las contraseñas de administrador y del sistema sin configurar. Para tener la BIOS fortificada habría que configurar una contraseña única y robusta para cada una de las opciones.

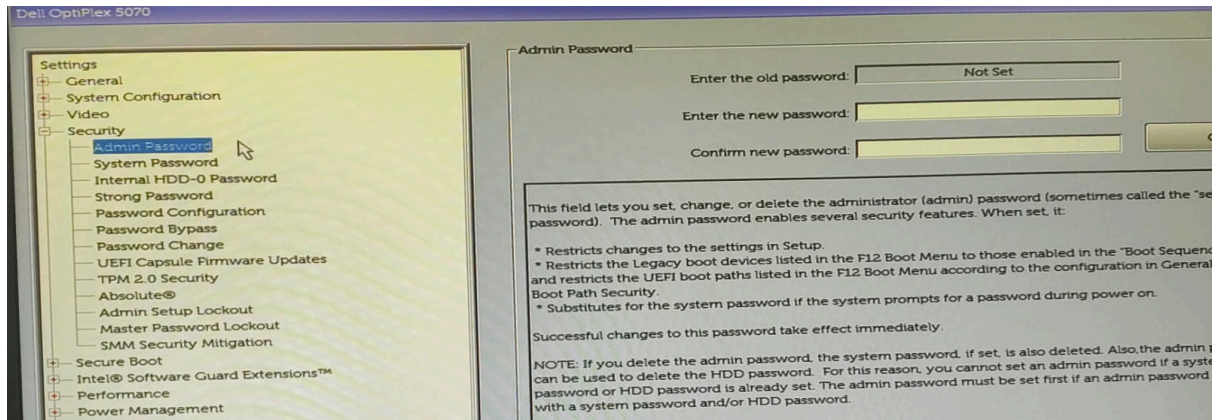


Figura 1. Imagen con la contraseña de Admin.

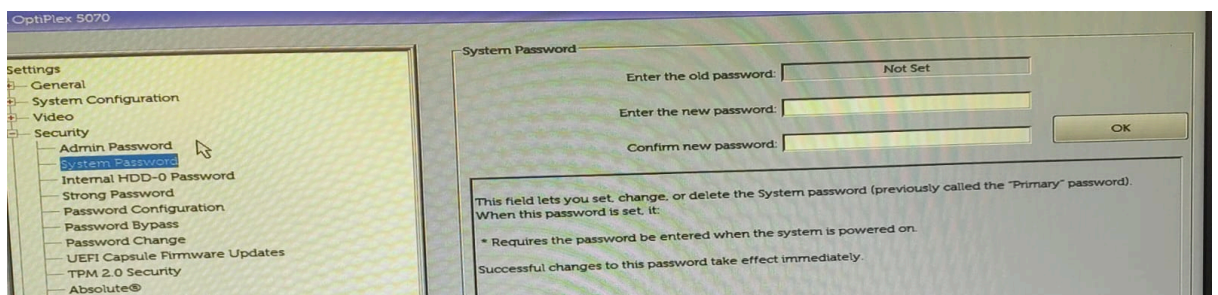


Figura 2. Imagen con la contraseña de System.

- Habilitar la carga de módulos adicionales compatible con UEFI. Durante el arranque, UEFI carga los módulos del hardware y controladores que tengan firma digital válida. En la configuración fortificada del equipo, se ha deshabilitado el "Legacy" habilitando solo UEFI confirmados. En la imagen de a continuación, se muestra la opción activada, habría que desactivarla.

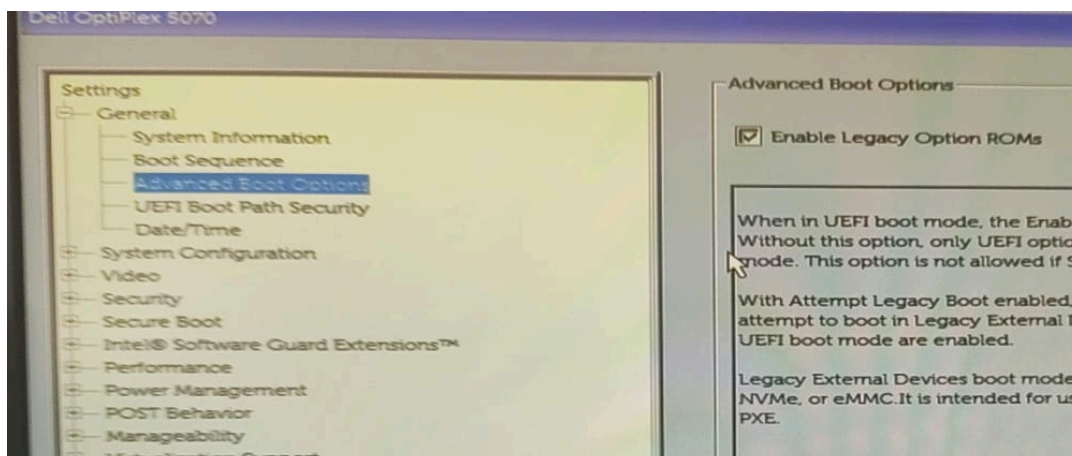


Figura 3. Imagen con la opción "Legacy Option ROMs".

- Activación de sistema Secure Boot. El Secure Boot es uno de los mecanismos más importantes de seguridad en sistemas UEFI. Esto verifica que el bootloader del sistema operativo esté firmado digitalmente con una clave de confianza. Si no es válida la firma, el arranque se bloquea. Por ello, hemos activado el Secure Boot y a mantener el modo de despliegue con clave de fabricante, garantizando la verificación de todos los binarios de arranque. Habría que activar la opción que se muestra deshabilitada en la siguiente imagen.

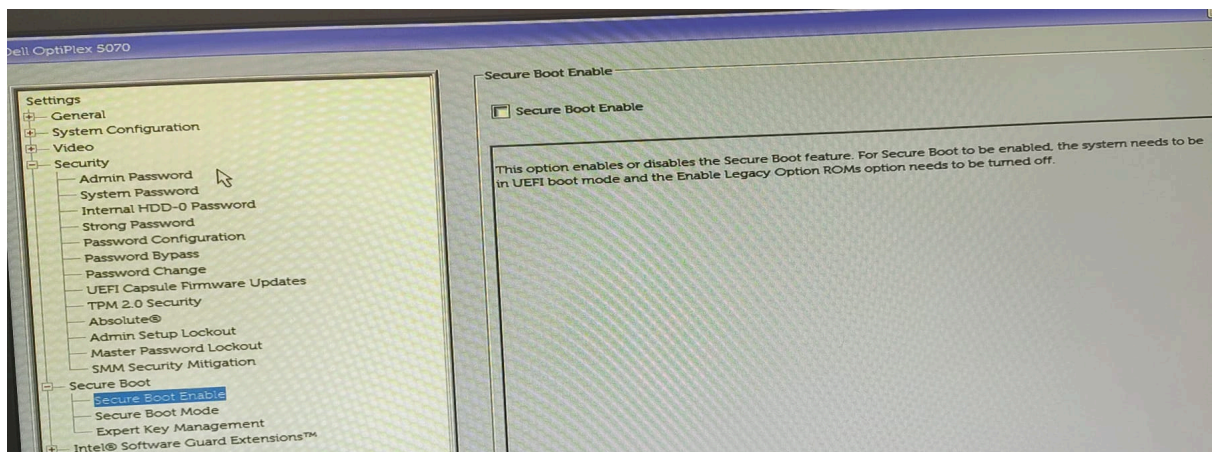


Figura 4. Imagen con Secure Boot.

- Modo de arranque UEFI. Se muestra que existen determinados sistemas que tienen la opción de habilitar el arranque del equipo como si fuera una BIOS convencional. Este tipo de sistemas se denominan sistema BIOS/UEFI. En el equipo de clase, hemos desactivado cualquier intento de arranque legacy. Habría que desactivar la siguiente opción.

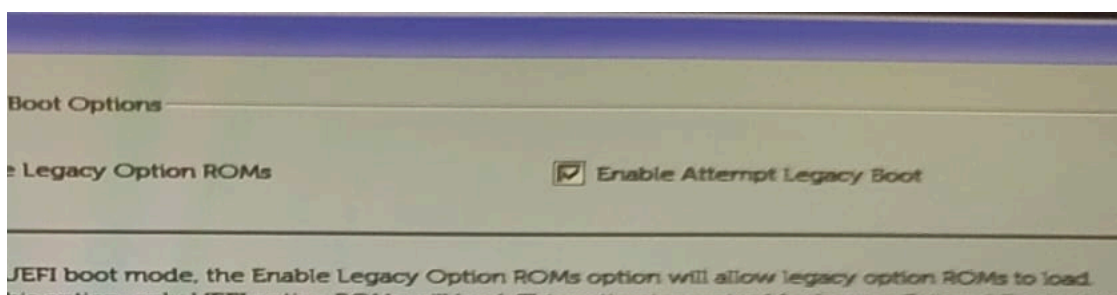


Figura 5. Imagen con la opción "Attempt Legacy Boot".

- Configuración de bases de datos claves del sistema Secure Boot. Secure Boot utiliza la base de datos de claves que determinan qué sistemas,

controladores o módulos pueden ejecutarse. En nuestro caso está activado el PK, que es la clave raíz de confianza, como la siguiente imagen.

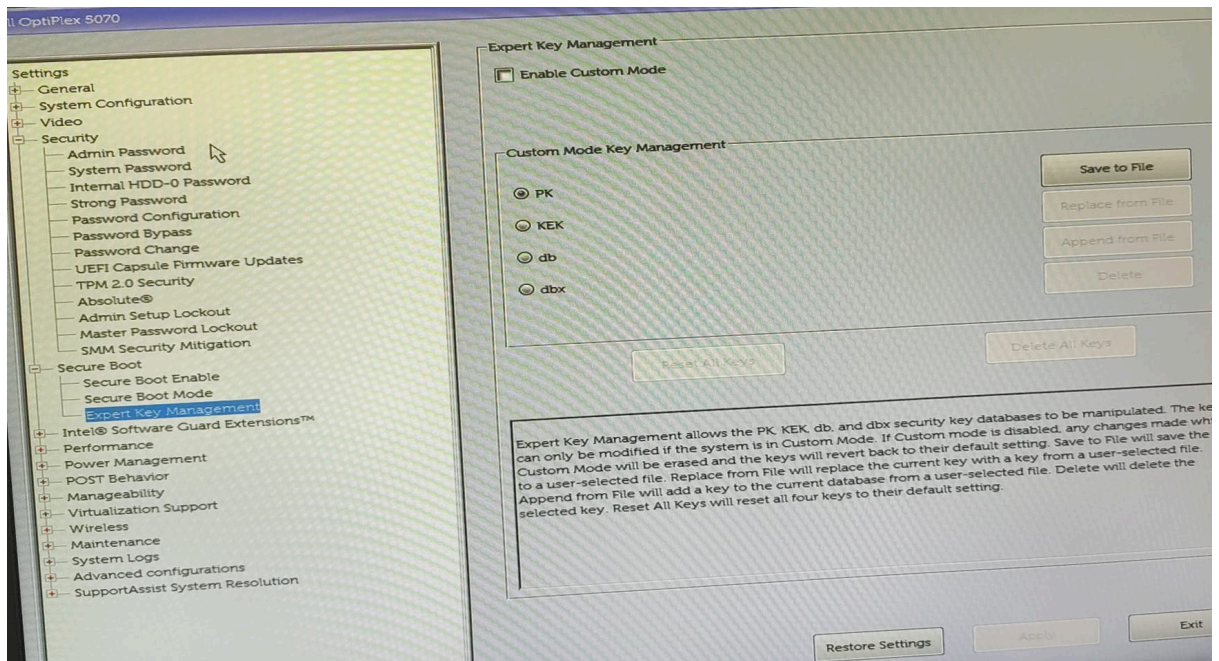


Figura 6. Imagen con la clave PK activada.

- Opciones de red UEFI. UEFI incluye opciones que permiten el arranque remoto mediante red. Esto es útil en entornos de gestión centralizada, pero en un aula o equipo individual puede suponer un riesgo. En este equipo, se deshabilitó el arranque de red, dejando solo el arranque desde disco, para evitar tener que controlar el servidor remoto. En la siguiente imagen, habría que seleccionar la opción “Disable”.

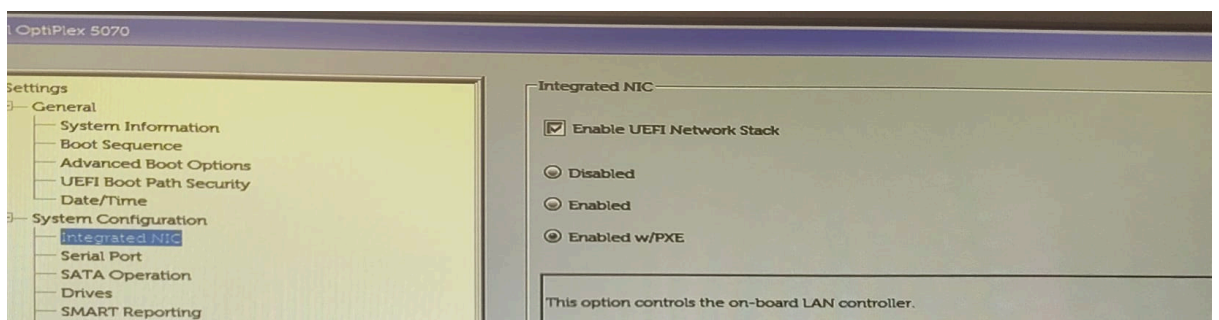


Figura 7. Imagen con la “Integrated NIC”.

6. Conclusión

Fortificar una BIOS/UEFI es un proceso complicado y variado. Requiere mucho tiempo, ya que primero necesitamos entender la BIOS y después poder separar los aspectos que impactan en la seguridad.

A continuación, tenemos que integrarlas dependiendo de la BIOS que tengamos. Y tenemos que tener en cuenta las amenazas y los mecanismos de seguridad que podamos implementar.

En conclusión, fortificar la BIOS es un proceso largo, tedioso y técnico. Requiere de conocimiento. También debería probarse antes de implementarse totalmente.

7. Webgrafía

[\[Manual del Optiplex para la identificación de las medidas de seguridad de la BIOS de clase\]](#)

[\[Visualización de la versión actualizable en la página oficial de Dell para la BIOS del equipo de clase\]](#)

[\[Documento para las amenazas y los mecanismos de seguridad de la BIOS\]](#)